

공유 링크가 안고 있는 **두 문제**

429 임계값과 OG 응답 — 왜 이 URL 하나가 특별한가

받은 질문

“429 임계값은 무슨 소리일까”

“OG 응답은 무슨 소리일까?”

0 같은 URL 이 두 방향으로 특별하다

공유 링크는 이 앱에서 유일하게 규칙이 다른 주소다.

`https://jungsan.devkdk.com/g/k3f9dq2`

└ 이 짧은 문자열이 전부다

다른 모든 API 는 로그인 토큰이 있어야 응답한다. 이 URL 만 문자열 자체가 열쇠다. 링크를 받은 사람이 아직 로그인하지 않았어도 모임 이름을 보여줘야 하기 때문이다.

그 성질에서 두 가지가 따라 나온다.

질문	무엇을 묻는 것인가	왜 이 URL 만 문제인가
4	429 임계값	열쇠가 짧은 문자열이라 맞춰서 들어올 수 있다. 몇 번까지 시도를 허용할지
5	OG 응답	단톡방에 붙이는 유일한 주소다. 붙였을 때 카드가 제대로 떴어야 한다

1 429 임계값

“이 주소를 1분에 몇 번까지 부르게 할지” 를 정하는 숫자다.

1.1 무엇을 막는 것인가

k3f9dq2 는 7글자다. 공격자는 아무 문자열이나 만들어 계속 요청한다. 하나만 맞으면 남의 모임 정보가 그대로 나온다.



1.2 숫자로 재보면

지금 토큰은 7자 · 소문자와 숫자(36종)다.

항목	값	계산
가능한 토큰 수	78,364,164,096	36^7
동시에 살아 있는 모임 (가정)	10,000	
한 번 찍어서 맞을 확률	$1 / 7,836,416$	$10,000 \div 36^7$
50% 맞추는 데 필요한 시도	약 543만 회	$\ln 2 \times 7,836,416$

543만 회가 커 보이지만, 얼마나 빨리 던질 수 있느냐에 달려 있다.

초당 요청	50% 도달까지	누가 할 수 있나
10	6.3 일	노트북 한 대
100	15 시간	클라우드 인스턴스 하나
1,000	1.5 시간	봇넷 · 분산 스크립트

막지 않으면 뚫린다

“확률이 낮다” 는 시도 횟수를 제한할 때만 성립한다. 제한이 없으면 확률이 낮은 사건은 그냥 오래 걸리는 사건이 된다.

1.3 그래서 두 가지가 필요하다 — 순서가 있다

	무엇	효과
근본	토큰을 길게	12자 · 62종 으로 늘리면 가능한 수가 $62^{12} \approx 3.2 \times 10^{21}$. 초당 1,000회로 던져도 50% 도 달에 5,100만 년
보조	429 제한	길이를 늘려도 대입 시도 자체를 볼 수 없다. 제한을 걸면 로그와 메트릭에 드러나고, 실수로 링크가 유출됐을 때 굵어가는 속도도 줄인다

길이가 먼저다

토큰이 짧으면 429 로 메울 수 없다. 분산해서 던지면 IP 당 제한은 그냥 IP 를 늘려서 피한다. 반대로 길이가 충분하면 429 는 없어도 뚫리지 않는다 — 그래도 두는 이유는 탐지와 비용 방어나다.

1.4 임계값 — 정상 사용자를 세어서 정한다

임계값은 감으로 정하는 숫자가 아니다. 정상 사용자가 이 주소를 몇 번 부르는지 세고, 거기에 여유를 준다.

```
// 링크를 받은 사람이 이 URL 을 부르는 횟수
카톡에서 링크 클릭      1회   모임 이름·참여자 확인
로그인하고 돌아옴      1회   myParticipantId 확인
참여 버튼              0회   POST join 은 다른 경로
참여 후 체크·결과      0회   gatheringId 로 옮겨간다 (API.md §5)

2~3회
```

참여 이후에는 이 URL 을 아예 부르지 않는다. 계약에서 토큰을 진입·참여에만 쓰기로 했기 때문이다. 그래서 제한을 낮게 걸어도 정상 사용에 걸리지 않는다.

규칙	제안	이유
IP 당 요청	분당 30회	정상 사용의 10배
연속 404	5회 → 10분 차단	맞추려는 시도만 여기 걸린다. 정상 사용자는 404 를 안 본다
성공(200) 응답	세지 않는다	↓ 아래

성공을 세면 정상 사용자가 막힌다

단톡방에 링크를 뿌리면 같은 회사 사무실의 20명이 같은 공인 IP(NAT) 로 들어온다. 카카오톡 인앱 브라우저는 미리보기까지 요청한다. 성공 응답까지 세면 뒤에 클릭한 사람이 429 를 받는다.

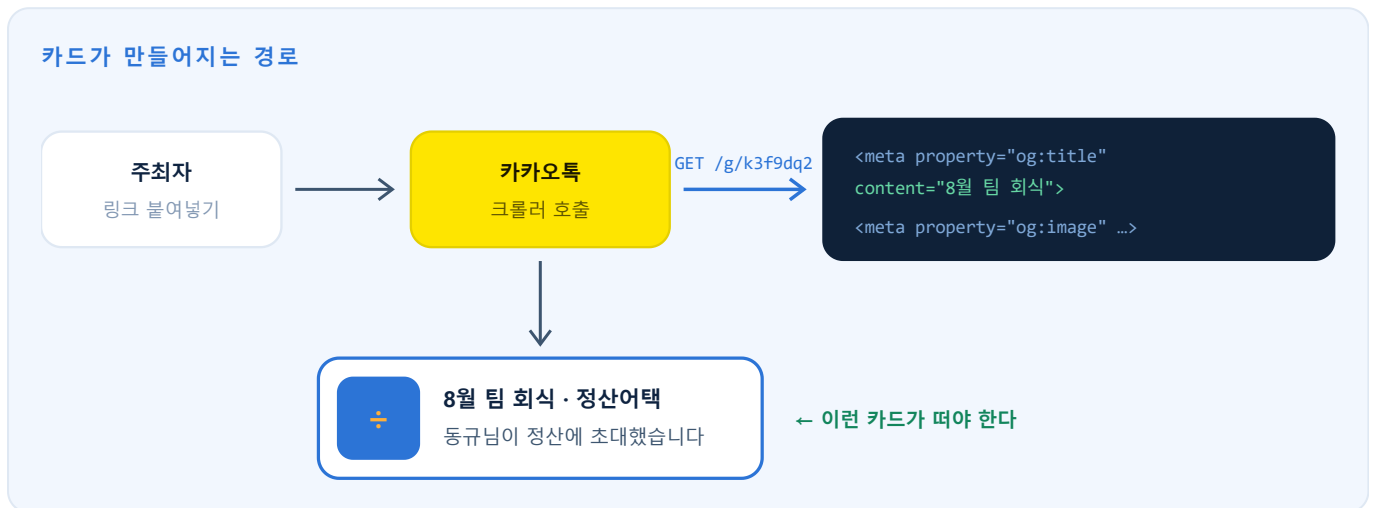
세야 하는 것은 요청 수가 아니라 틀린 요청 수다.

2 OG 응답

단톡방에 링크를 붙였을 때 뜨는 **카드**를 만드는 태그다.

2.1 그 카드는 누가 만드나

OG 는 **Open Graph**다. 카카오톡·슬랙·페이스북이 공통으로 읽는 규격이다. 링크를 붙이면 그 서비스의 크롤러가 URL 을 직접 GET 해서 HTML <head> 의 태그를 읽어 카드를 만든다.



2.2 지금 우리가 주고 있는 것 — 실측

배포된 index.html 을 직접 받아 확인했다.

```
// C:\dev\profile\index.html · jungsan.devkdk.com 실측
og: 태그      0개
<title>       김동규 | Backend Developer
<meta description> 백엔드 개발자 김동규의 개인 사이트 -
                  개발 철학과 프로젝트(ValkyrieFS, 24시간이모자라)를 소개합니다.
```

지금 단톡방에 링크를 붙이면

카드에 “김동규 | Backend Developer” 와 포트폴리오 소개문이 뜬다. 모임 이름도, 누가 초대했는지도 없다. 받은 사람은 무슨 링크인지 알 수 없어 누르지 않는다.

2.3 왜 JS 로 고칠 수 없나 — 이게 핵심이다

“그럼 화면에서 document.title 을 바꾸면 되지 않나” 가 자연스러운 생각인데, 안 된다.

브라우저와 크롤러가 받는 것이 다르다

사람의 브라우저

- ① HTML 받음 → 빈 껍데기
- ② JS 실행
- ③ API 호출 → 모임 데이터
- ④ 화면 그림

"8월 팀 회식" 보인다

카카오톡 크롤러

- ① HTML 받음 → 빈 껍데기
- ② JS 실행 안 함
- ③ API 호출 안 함
- ④ 화면 안 그림

<title> 만 읽고 끝

크롤러는 JS 를 실행하지 않는다. 우리 프론트는 CSR(Client-Side Rendering) SPA 라 모임 이름이 JS 가 API 를 부른 뒤에야 생긴다. 크롤러가 받는 HTML 에는 그 정보가 아직 없다.

그래서 프론트만으로는 해결할 수 없다

이건 화면 코드의 문제가 아니라 누가 그 HTML 을 만들어 주느냐의 문제다. 백엔드가 `/g/{token}` 을 HTML 로도 응답해야 한다.

2.4 같은 URL 에 두 손님이 온다

// GET `/g/k3f9dq2` 를 받았을 때

크롤러 → **og: 태그가 든 HTML**

모임 이름 · 주최자 · 아이콘

사람 → 정산어택 화면

참여 버튼까지

가르는 방법이 세 가지 있다. 어느 것을 쓸지는 ADR-007 에서 정한다.

방법	장점 / 걸리는 점
A 공유 링크를 백엔드 도메인으로 <code>api.../g/{t}</code>	+ 가장 단순하다. 백엔드가 HTML 을 주고 사람은 프론트로 보낸다 - 단독방에 뜨는 주소가 <code>jungsan.devkdk.com</code> 이 아니다
B Vercel rewrite <code>/g/*</code> → 백엔드	+ 주소가 그대로 <code>jungsan.devkdk.com/g/...</code> - 사람을 프론트로 되돌릴 때 같은 경로로 다시 들어와 순환한다. 경로를 하나 더 뒤야 한다
C Cloudflare Worker User-Agent 로 분기	+ 주소도 그대로고 순환도 없다. 크롤러만 백엔드로 보낸다 - <code>jungsan.devkdk.com</code> 을 오렌지 구름으로 되돌려야 Worker 가 붙는다

C 를 쓰면 방금 한 DNS 설정을 되돌려야 한다

`jungsan.devkdk.com` 을 DNS only(회색 구름) 으로 뒀다. Cloudflare Worker 는 프록시를 지나는 요청에 만 붙으므로, C 를 고르면 오렌지 구름으로 바꾸고 SSL/TLS 를 Full (strict) 로 맞춰야 한다. 그 대가로 429 를 서버가 아니라 Cloudflare 가 걸 수 있다 — 질문 4 와 5 가 여기서 만난다.

3 정해야 하는 것

두 질문의 답은 셋으로 좁혀진다.

항목	제가 원하는 값	왜
1 shareToken 길이	12자 · 62종 지금 7자 · 36종	길이가 근본이고 비용이 0 이다. 지금 바꾸면 나중에 마이그레이션이 없다
2 429 임계값	IP당 분당 30회 연속 404 5회 → 10 분 성공은 세지 않음	정상 사용이 2~3회다. 틀린 요청만 세면 NAT 뒤 20명이 안 막힌다
3 OG 방식	A (백엔드 도메인) 또는 C (Worker)	A 는 지금 당장 되고, C 는 주소가 예쁘다. B 는 순환 때문에 경로가 지저분해진다

토큰 길이는 지금 정하는 게 싸다

아직 발급된 토큰이 하나도 없다. **스키마를 만들기 전에 정하면 컬럼 길이 하나로 끝난다**. 운영 중에 바꾸면 이미 단톡방에 뿌려진 링크를 살려두면서 새 형식을 함께 받아야 한다.

정산어택 · 기술 메모 01 · docs/explain/01-share-link.html · 본문의 실측값은 배포본 jungsan.devkdk.com 에서 직접 받아 확인한 것이다.